



Идентитет, аутентикација и RBAC

Од идентитета корисника до проверљиве одлуке о приступу

Циљ: раздвојити ко је субјекат од онога што сме

Успешна пријава није дозвола за радњу; она је тек улаз у одлуку о приступу.

РАЗУМЕТИ

Четири различита појма

Идентитет, аутентикација, улога и дозвола имају различите одговорности у систему.

ПРИМЕНИТИ

Одлука је на серверу

Интерфејс може сакрити опцију, али не сме бити једина контрола приступа.

ДОКАЗАТИ

Дозвољено и одбијено

Тест и audit запис показују шта се догодило за исти тип радње у два контекста.

ПИТАЊЕ ЗА ПРОВЕРУ

Питање за крај вежбе: ко је субјекат, која дозвола је потребна и у ком опсегу она важи?

Једна успешна пријава не решава безбедносни проблем

Грешка настаје када систем споји доказ идентитета и право на радњу у једну претпоставку.

НЕБЕЗБЕДНА ПРЕТПОСТАВКА

„Пријављен је, дакле сме“

Корисник може бити исправно аутентификован, а ипак не сме да одобри промену, чита туђи ресурс или мења конфигурацију.

ПОТПУНА ОДЛУКА

„Ко, шта, над чим и зашто?“

Сервер проверава активан идентитет, потребну дозволу, опсег и контекст конкретне радње.

КЉУЧНА ПОРУКА

Раздвајање појмова смањује број скривених пречица и омогућава јасан audit траг.

Четири појма граде једну одлуку

Сваки елемент одговара на друго питање и оставља другачији доказ.

01

Идентитет

Ко је субјекат?
Трајна ознака и статус.

02

Аутентикација

Да ли је тврдња о идентитету
уверљива?

03

Улога

Коју пословну одговорност
субјекат има?

04

Дозвола

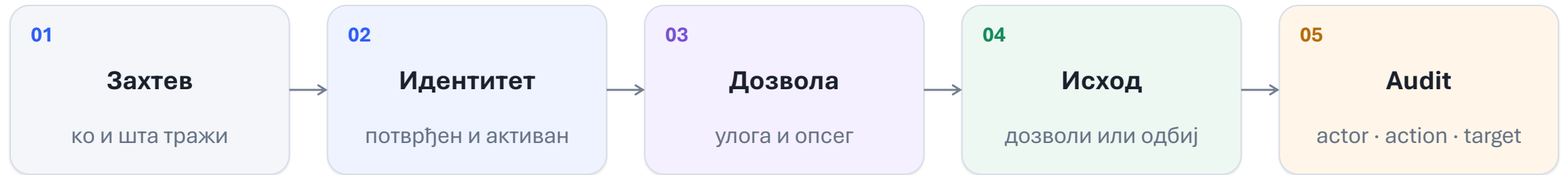
Коју конкретну радњу сме да
изврши?

МОДЕЛ ОДЛУКЕ

Ефективно право = улога + дозвола + опсег + актуелни статус идентитета

Одлука о приступу је низ проверљивих питања

Када сваки корак има јасан улаз и исход, лакше је написати тест и објаснити одбијање.



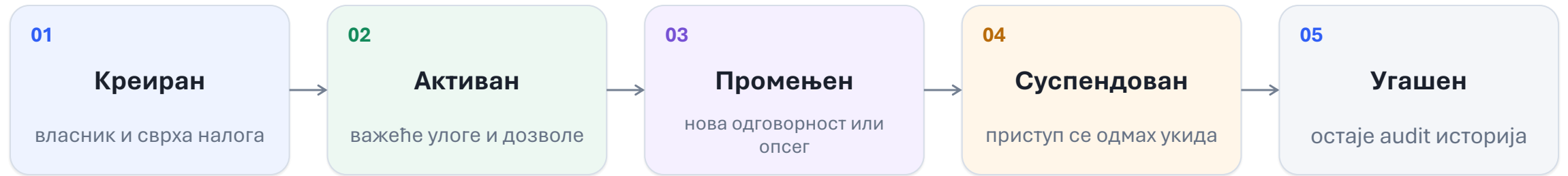
КЉУЧНА ПОРУКА

Клијент може да води корисника, али сервер остаје једини ауторитет за одлуку.

Одбијање треба да буде контролисано: довољно јасно клијенту, без откривања заштићених детаља.

Идентитет има животно циклус

Право приступа не зависи само од података у тренутку креирања налога.



ДИЗАЈНЕРСКА ПОСЛЕДИЦА

Дизајнерска последица

Статус идентитета и промена улоге морају утицати на сваку нову одлуку — без ослањања на застарелу претпоставку клијента.

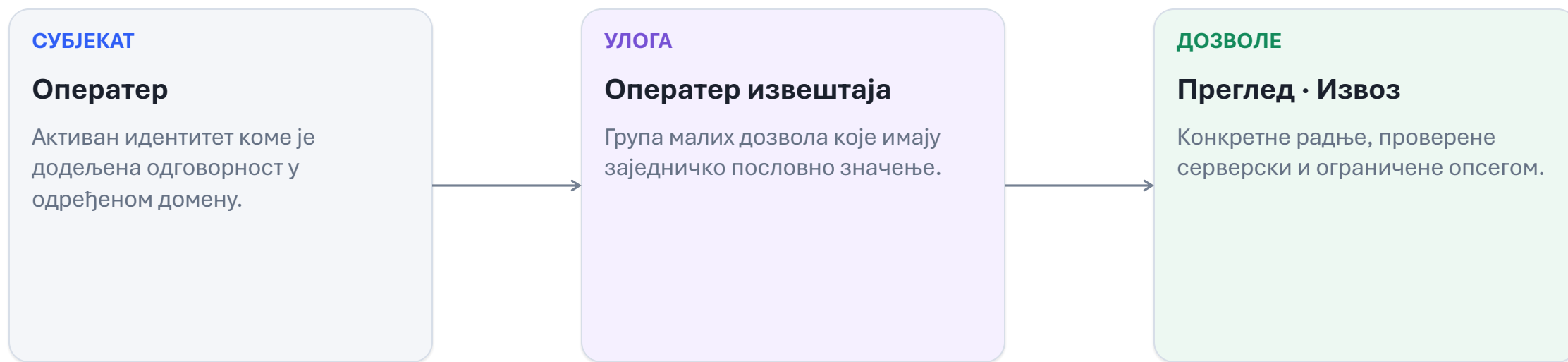
Аутентикација и ауторизација одговарају на различита питања

Мешање ова два корака најчешће ствара преширока права.

ПОЈАМ	ПИТАЊЕ	ТИПИЧНА ГРЕШКА
Идентитет	Ко је субјекат?	Особа и технички налог се третирају исто.
Аутентикација	Да ли је идентитет потврђен?	Успешна пријава се тумачи као широко овлашћење.
Ауторизација	Да ли је радња дозвољена?	Провера постоји само у корисничком интерфејсу.
Сесија	У ком привременом контексту право важи?	Token се третира као трајно право.

RBAC повезује дозволе са пословном одговорношћу

Улога није једна дозвола, нити треба да постане неограничен пакет изузетака.



ПРИНЦИП

Најмања привилегија: додели само право које је потребно, за опсег у коме је потребно и док потреба траје.

Сервер доноси коначну одлуку

Политика именује потребну дозволу; провера не зависи од тога да ли је дугме видљиво.

```
1 [Authorize]
2 [HttpPost("reports/{id}/approve")]
3 public IActionResult Approve(Guid id)
4 {
5     if (!access.Can(User, "report.approve", id))
6         return Forbid();
7
8     reports.Approve(id);
9     return NoContent();
10 }
```

Шта је важно

Пријава даје идентитет, не право на approve.
Дозвола је именована као конкретна радња.
Провера укључује и конкретан ресурс.
Одбијање се дешава пре пословне промене.

UI је помоћ, не контрола

Исти захтев мора бити безбедан и када се API позове директно.

Негативни тест описује границу приступа

Кориснији је тест који доказује одбијање него још један тест успешне пријаве.

```
1 [Test]
2 public void Viewer_cannot_approve_report()
3 {
4     var user = User.WithRole("Viewer");
5
6     var result = api.Approve(report.Id, user);
7
8     Assert.That(result.StatusCode, Is.EqualTo(403));
9     audit.AssertDenied(user.Id, "report.approve", report.Id);
10 }
```

Доказ има два слоја

ИСХОД

403 — радња је одбијена

Стање ресурса остаје непромењено.

ТРАГ

Audit бележи покушај

Actor, action, target и исход могу се касније објаснити.

Пример: оператер добија привремену одговорност

Најбрже решење — широка администраторска улога — отвара више радњи него што је потребно.

ПОТРЕБА

Одобри једну врсту промене

Прво се именује конкретна радња, а не најшира постојећа улога.

ОПСЕГ

Само један домен и ограничено време

Право не важи за цео систем и не остаје активно после потребе.

РЕВИЗИЈА

Истек и audit траг

Може се утврдити ко је доделио право, зашто и када је престало.

КЉУЧНА ПОРУКА

Добар RBAC модел не пита „коју највећу улогу можемо дати“, већ „која је најмања радња оправдана“.

Три грешке које треба препознати одмах

Свака делује практично у првој итерацији, али касније постаје скривена безбедносна рупа.

01

Пријава = овлашћење

Систем не проверава посебно радњу и ресурс јер је корисник већ пријављен.

02

Преширока улога

Нова потреба се решава додавањем администратора уместо мале дозволе и опсега.

03

Сакривено дугме

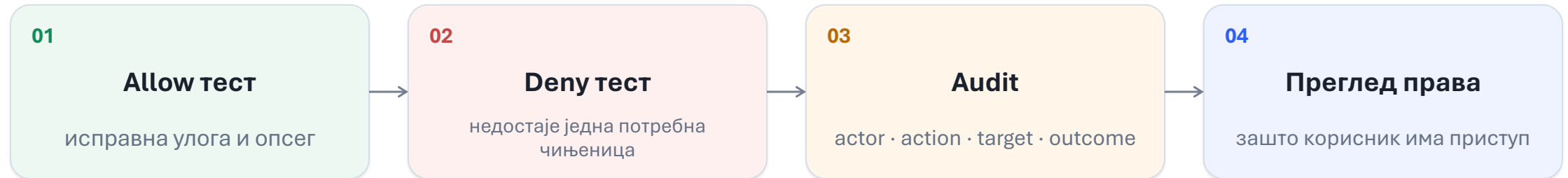
Клијент не приказује радњу, али сервер прихвата директан API позив.

КОНТРАМЕРА

Контрамера за све три: експлицитна серверска одлука + негативан тест + audit исход.

Како знамо да модел приступа ради

Један позитиван сценарио није довољан; потребан је доказ границе и објашњивог разлога.



ПРОВЕРЉИВ ЗАКЉУЧАК

Систем дозвољава оправдану радњу, одбија исту радњу без потребне дозволе и оставља траг који други члан тима може да понови и објасни.

Задатак после прве вежбе

Примените принцип на додељеној пројектној целини; не копирајте готов модел улога без доменског разлога.

ИМПЛЕМЕНТАЦИЈА

Једна безбедносна одлука

Идентификујте субјекат, радњу, дозволу и опсег. Одлуку спроведите серверски и повежите је са актуелним статусом идентитета.

ДОКАЗ

Један allow и један deny сценарио

Припремите тест или демонстрацију и audit запис који показује actor, action, target и исход.

ПРИПРЕМА ЗА P1

Припрема за P1 (после вежби 1–2): основна аутентикација и RBAC раде серверски; object-level authorization и негативан тест допуњују ланац.

Провера разумевања

Тема је савладана када одлуку, њен контекст и доказ можете објаснити без ослањања на назив framework-а.

ПИТАЊЕ

За једну административну радњу објасните:

ко је субјекат · која дозвола је потребна · у ком опсегу важи · шта се бележи када је радња одбијена

Можете ли исту одлуку да формулишете као allow и deny тест?

Шта се мења ако је идентитет суспендован након пријаве?

Како доказујете да UI није једина контрола приступа?

Чување лозинке

Систем не чува лозинку као текст и не пореди је ручно са вредношћу из базе.

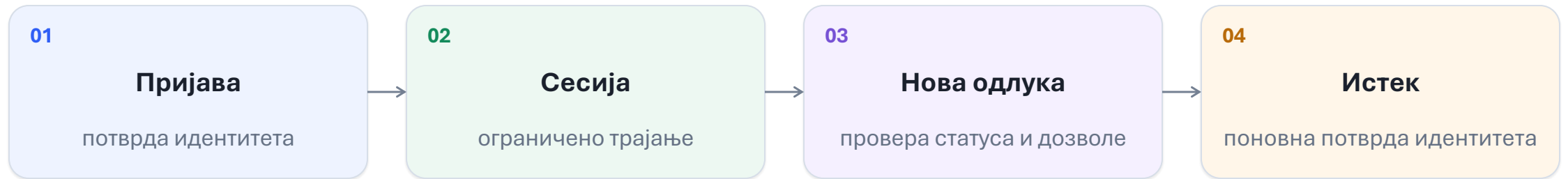
```
1 public PasswordRecord Create(string password)
2 {
3     var hash = hasher.HashPassword(user, password);
4     return new PasswordRecord(hash);
5 }
6
7 public bool Verify(string password, string hash)
8 {
9     return hasher.VerifyHashedPassword(user, hash, password)
10        == PasswordVerificationResult.Success;
11 }
```

Шта је важно

- 01 Стандардна библиотека управља хеширањем и salt вредношћу.
- 02 Иста порука покрива непостојећи налог и погрешну лозинку.
- 03 Промена лозинке укида стару тајну и оставља audit траг.

Сесија је привремени контекст

Токен преноси тврдње о субјекту, али не сме да претвори привремено стање у трајно право.



БЕЗБЕДНОСНИ ИСХОД

Суспензија мора да има ефекат

Активан токен не сме сам по себи да надјача актуелни статус идентитета за нову осетљиву радњу.

Именованње улога и дозвола

Назив треба да открије пословну одговорност и конкретну радњу коју систем штити.

ПРЕШИРОКО

Admin

Назив не објашњава које радње су оправдане, над којим ресурсима и колико дуго право важи.

ПРЕЦИЗНО

Оператер извештаја

Улога групише дозволе report.view и report.export у опсеру домена за који оператор одговара.

ПРАВИЛО МОДЕЛА

Промена пословне одговорности мења улогу. Нова техничка операција додаје малу дозволу у постојећи модел.

Audit запис одговара на питање шта се догодило

Лог има вредност када други члан тима може да реконструише покушај без откривања тајни.

```
1 {  
2   "actor": "user-184",  
3   "action": "report.approve",  
4   "target": "report-902",  
5   "outcome": "denied",  
6   "reason": "missing_permission",  
7   "correlationId": "c-71f2"  
8 }
```

ДОВОЉНО ЗА ОБЈАШЊЕЊЕ

Субјекат, радња, циљ и исход

Correlation ID повезује одлуку са остатком тока захтева.

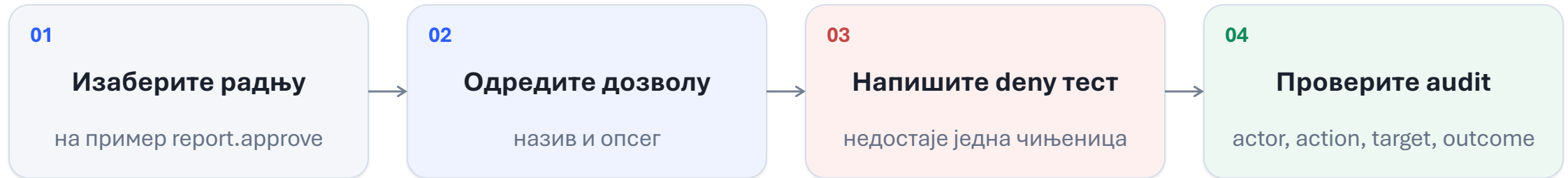
НЕ ПРИПАДА У ЛОГ

Лозинка, token и непотребни лични подаци

Audit траг не сме да постане нови извор цурења осетљивих вредности.

Мини вежба

На једној радњи изградите цео ланац од субјекта до доказа.



РЕЗУЛТАТ ЗА РЕПОЗИТОРИЈУМ

Резултат за репозиторијум

Мала серверска промена, позитиван и негативан тест и кратко објашњење зашто дозвола има баш тај опсег.